

Dossier de conception · réseau et protocoles

Six scénarios pédagogiques

Chaque scénario part d'une situation ordinaire — une configuration héritée, un raccourci pris un jour d'urgence, un avertissement que tout le monde a cessé de lire — et la transforme en problème à résoudre. Le joueur n'apprend pas qu'un protocole est dangereux : il constate ce qu'un tiers peut en faire, puis corrige.

Ces six situations complètent les scénarios existants de la plateforme, centrés sur l'interception de protocoles applicatifs. Elles portent ici sur l'administration du réseau, la traçabilité et la chaîne de confiance — trois angles qui n'étaient pas couverts.

Principes de conception retenus

- Partir d'une négligence plausible plutôt que d'un attaquant abstrait : les élèves reconnaissent la situation, donc ils la retiennent.
- Faire constater avant d'expliquer. La théorie arrive après la démonstration, jamais avant.
- Une seule notion centrale par scénario, et des notions secondaires qui s'y rattachent.
- Terminer par une action de remédiation vérifiable, pas par un simple questionnaire.

01 **SNMP · Supervision réseau**

La supervision qui trahit le réseau

Mise en situation

L'équipe informatique du lycée supervise ses commutateurs et ses imprimantes avec un outil de métrologie installé il y a six ans. Personne n'y a retouché depuis. Un audit signale que l'ensemble du parc répond à des requêtes SNMP émises depuis n'importe quel poste du réseau, avec la communauté « public ». Le joueur découvre qu'en une commande, il peut lister les interfaces, les tables de routage et les noms d'hôtes de tout l'établissement — sans aucun identifiant.

Rôle du joueur	Administrateur réseau
Protocoles	SNMP v1 / v2c / v3, UDP 161
Niveau	Intermédiaire — NSI terminale, BTS SIO
Durée estimée	≈ 45 minutes

Objectif du joueur

Comprendre que SNMP v1 et v2c n'authentifient l'appelant qu'au moyen d'une chaîne de caractères transmise en clair, cartographier ce qu'un attaquant peut en tirer, puis migrer le parc vers SNMPv3 avec authentification et chiffrement.

Progression

1. Interroger un commutateur avec la communauté par défaut et constater la quantité d'informations renvoyées sans authentification.
2. Identifier les équipements du parc encore configurés en v1 ou v2c à partir d'un inventaire fourni.
3. Expliquer, dans un court QCM, pourquoi une communauté en lecture seule reste un problème : la reconnaissance précède l'attaque.
4. Configurer SNMPv3 sur trois équipements — utilisateur, authentification, chiffrement — et restreindre les requêtes au sous-réseau d'administration.
5. Vérifier que l'ancienne communauté ne répond plus.

Notions mobilisées

- Différence entre authentification et simple mot de passe partagé
- Chiffrement du transport : ce que v3 apporte que v2c n'a pas
- Phase de reconnaissance dans une intrusion
- Filtrage par sous-réseau d'administration

Critères de validation

- Les trois équipements répondent en v3 et rejettent les requêtes v2c
- Le joueur sait citer deux informations exploitables obtenues en lecture seule
- Le QCM sur la distinction lecture seule / écriture est réussi

02 NTP • Traçabilité

Quand l'heure fausse l'enquête

Mise en situation

Un incident est signalé un mardi matin : un compte a été utilisé pour accéder à des dossiers auxquels il n'aurait pas dû avoir accès. Le joueur reçoit les journaux de trois machines pour reconstituer la chronologie. Problème : les horodatages ne concordent pas. Le serveur de fichiers a onze minutes d'avance, un poste a quarante secondes de retard, et un troisième équipement affiche encore l'heure d'hiver. Impossible de dire ce qui s'est produit avant quoi.

Rôle du joueur Analyste en centre de supervision

Protocoles NTP, UDP 123

Niveau Intermédiaire

Durée estimée ≈ 40 minutes

Objectif du joueur

Comprendre que la synchronisation horaire n'est pas un confort mais un prérequis de toute investigation, et qu'une dérive d'horloge casse aussi bien la corrélation de journaux que certains mécanismes d'authentification.

Progression

1. Tenter de reconstruire la chronologie de l'incident à partir des trois journaux non synchronisés — et constater que deux ordres contradictoires sont également défendables.
2. Identifier la source de la dérive : deux machines interrogent un serveur NTP différent, la troisième n'en interroge aucun.
3. Découvrir un effet de bord : les tickets d'authentification d'un des postes sont rejetés parce que l'écart dépasse la tolérance admise.
4. Configurer une source de temps unique et cohérente sur les trois machines.
5. Rejouer la reconstruction chronologique et produire la bonne séquence d'événements.

Notions mobilisées

- Corrélation de journaux et notion de source de temps de référence
- Tolérance d'écart horaire dans les protocoles d'authentification
- Fuseaux horaires et UTC dans la journalisation
- Intégrité de la preuve numérique

Critères de validation

- La chronologie finale est correcte et justifiée
- Le joueur explique pourquoi horodater en UTC facilite l'investigation
- Les trois machines partagent la même source de temps

03 **RDP · Exposition sur Internet**

La porte laissée ouverte sur la rue

Mise en situation

Pendant une période de télétravail, un administrateur pressé a ouvert le port 3389 du serveur de gestion directement sur Internet, « le temps que ça se calme ». Deux ans plus tard, l'ouverture est toujours là. Le joueur reprend le poste et découvre dans les journaux d'authentification plusieurs milliers de tentatives de connexion quotidiennes, provenant d'adresses réparties dans le monde entier.

Rôle du joueur	Administrateur système
Protocoles	RDP, TCP 3389
Niveau	Débutant à intermédiaire
Durée estimée	≈ 50 minutes

Objectif du joueur

Mesurer ce que signifie exposer un service d'administration sur Internet, comprendre l'économie d'une attaque automatisée, et mettre en place un accès distant qui ne repose pas sur la seule solidité d'un mot de passe.

Progression

1. Analyser les journaux d'authentification : compter les tentatives, repérer les comptes visés, identifier les noms d'utilisateur testés en priorité.
2. Comprendre pourquoi ces tentatives sont automatisées et pourquoi le coût pour l'attaquant est quasi nul.
3. Fermer l'exposition directe et placer le service derrière un accès distant authentifié.
4. Ajouter un second facteur d'authentification et une politique de verrouillage après échecs répétés.
5. Vérifier dans les journaux que les tentatives externes n'atteignent plus le service.

Notions mobilisées

- Surface d'exposition et principe de moindre exposition
- Attaque par force brute et par bourrage d'identifiants
- Second facteur d'authentification
- Lecture de journaux d'authentification

Critères de validation

- Le port n'est plus joignable depuis l'extérieur
- Le second facteur est actif sur les comptes d'administration
- Le joueur sait expliquer pourquoi un mot de passe long ne suffit pas seul

04 **SMB · Partages de fichiers** L'héritage que personne n'a osé débrancher

Mise en situation

Le serveur de fichiers d'une PME héberge quatorze partages. Trois d'entre eux sont accessibles au groupe « Tout le monde » en lecture et écriture, dont un dossier « Comptabilité — archives ». Le protocole SMB v1 est toujours activé parce qu'une vieille imprimante multifonction en aurait besoin. Le joueur doit reprendre l'ensemble.

Rôle du joueur Ingénieur cybersécurité

Protocoles SMB v1 / v3, TCP 445

Niveau Intermédiaire

Durée estimée ≈ 45 minutes

Objectif du joueur

Comprendre la différence entre un partage ouvert par négligence et un partage correctement cloisonné, et pourquoi le maintien d'un protocole obsolète pour un seul équipement met en danger tout le reste.

Progression

1. Parcourir les partages depuis un compte utilisateur ordinaire et lister ce qui est accessible sans droit particulier.
2. Établir la cartographie des permissions réelles, par opposition aux permissions supposées.
3. Comprendre le mécanisme de propagation latérale : ce qu'un attaquant ayant compromis un seul poste peut atteindre depuis ce partage.
4. Restreindre les partages sensibles aux groupes concernés et retirer l'accès à « Tout le monde ».
5. Traiter le cas de l'imprimante : isoler l'équipement plutôt que maintenir le protocole obsolète pour l'ensemble du serveur.

Notions mobilisées

- Principe du moindre privilège appliqué aux partages
- Différence entre permissions de partage et permissions du système de fichiers
- Propagation latérale après compromission d'un poste
- Traitement d'un équipement hérité : isoler plutôt que dégrader

Critères de validation

- Aucun partage sensible n'est accessible à « Tout le monde »
- SMB v1 est désactivé sur le serveur
- Le joueur propose une solution pour l'imprimante sans réactiver le protocole

05 **DHCP · Attaque réseau**

L'attaquant qui distribue les adresses

Mise en situation

Depuis quelques jours, certains postes d'une salle informatique reçoivent une configuration réseau anormale : la passerelle indiquée n'est pas celle de l'établissement, et le serveur de noms est inconnu. Les autres postes fonctionnent normalement. Le joueur doit comprendre pourquoi certaines machines sont touchées et d'autres non.

Rôle du joueur Administrateur réseau

Protocoles DHCP, UDP 67 / 68

Niveau Intermédiaire à avancé

Durée estimée ≈ 50 minutes

Objectif du joueur

Comprendre qu'un client DHCP accepte la première réponse qui lui parvient, sans vérifier qui l'a émise, et que cette course détermine par où passera tout le trafic de la machine.

Progression

1. Comparer la configuration réseau de deux postes, l'un sain, l'autre détourné.
2. Reconstituer l'échange DHCP et comprendre que le client retient la première offre reçue : c'est une question de vitesse, pas de légitimité.
3. Mesurer la conséquence : une passerelle contrôlée par un tiers voit passer l'intégralité du trafic sortant du poste.
4. Localiser l'équipement pirate à partir de la table d'adresses du commutateur.
5. Activer la protection appropriée sur les ports du commutateur pour n'autoriser les réponses DHCP que depuis le port du serveur légitime.

Notions mobilisées

- Déroulé d'un échange DHCP et absence d'authentification du serveur
- Position d'intercepteur sur le chemin réseau
- Table d'adresses physiques d'un commutateur
- Protection au niveau du port de commutation

Critères de validation

- Les postes affectés retrouvent la configuration légitime
- La protection est active sur les ports d'accès et absente du port serveur
- Le joueur explique pourquoi le hasard désigne les victimes

06 TLS · Certificats

Apprendre aux utilisateurs à ignorer les alertes

Mise en situation

L'intranet de l'établissement présente un certificat auto-signé depuis son installation. Chaque matin, deux cents personnes voient un avertissement de sécurité, cliquent sur « continuer quand même » et poursuivent. Le joueur découvre qu'un service interne supplémentaire vient d'être mis en ligne avec un certificat expiré — et que personne ne l'a signalé, parce que plus personne ne lit ces messages.

Rôle du joueur	Ingénieur cybersécurité
Protocoles	TLS, HTTPS, certificats X.509
Niveau	Intermédiaire
Durée estimée	≈ 40 minutes

Objectif du joueur

Comprendre que le vrai dégât d'un mauvais certificat n'est pas technique mais comportemental : il désapprend aux utilisateurs à distinguer une alerte légitime d'une attaque réelle.

Progression

1. Inspecter trois certificats — un valide, un auto-signé, un expiré — et identifier ce que chacun prouve ou ne prouve pas.
2. Comprendre ce que le chiffrement garantit ici, et ce que seule l'autorité de certification peut garantir : l'identité du serveur.
3. Simuler une interception : un attaquant présente son propre certificat, l'utilisateur habitué clique et poursuit.
4. Mettre en place une autorité interne et déployer sa racine sur le parc, ou basculer sur des certificats reconnus.
5. Vérifier qu'aucun service interne ne produit plus d'avertissement, et rédiger la consigne à donner aux utilisateurs.

Notions mobilisées

- Ce que garantit le chiffrement, ce que garantit l'authentification du serveur
- Chaîne de confiance et autorité de certification
- Lassitude face aux alertes et coût pédagogique d'un faux positif permanent
- Interception sur canal chiffré

Critères de validation

- Les trois services internes sont joignables sans avertissement
- Le joueur distingue une erreur d'expiration d'une erreur d'identité
- La consigne rédigée est compréhensible par un non-technicien